

LAPORAN AUDIT KEAMANAN APLIKASI WEB

Vulnerability Assessment terhadap bWAPP (Buggy Web Application)

Auditor: Ravi Arnan Irianto

Mata Kuliah: IT Audit

Target: bWAPP (OWASP) - Docker, <http://localhost:8080>

Standar: OWASP Top 10 2021



Apa itu bWAPP?

bWAPP (Buggy Web Application) adalah aplikasi web PHP/MySQL yang **sengaja dibuat rentan** untuk tujuan edukasi keamanan, dikembangkan oleh Malik Mesellem. Aplikasi ini menjadi sarana legal untuk mempraktikkan teknik audit dan pengujian penetrasi dalam lingkungan terisolasi.

100+

Jenis kerentanan tersistematis

3

Tingkat kesulitan (Low / Medium / High)

2

Metode deploy (Docker / Bee-Box VM)

Catatan: bWAPP bukan aplikasi yang error, melainkan dirancang untuk dieksploitasi sebagai media latihan.

Kenapa bWAPP untuk IT Audit?

- **Coverage terluas:** 100+ kerentanan dalam satu platform.
- **Selaras OWASP:** tiap bug mudah dipetakan ke framework standar.
- **Setup cepat:** siap pakai via Docker dalam hitungan menit.
- **Bertingkat:** 3 level kesulitan untuk simulasi bertahap.

Platform	Jumlah Bug
bWAPP	100+
Juice Shop	~75
WebGoat	~35
DVWA	~15

bWAPP mengungguli platform sejenis dalam cakupan kerentanan.

Setup dan Lingkungan Lab

Deployment via Docker (terisolasi ke localhost):

```
$ docker run -d -p 8080:80 \
  hackersploit/bwapp-docker
# inisialisasi DB sekali:
http://localhost:8080/install.php
```

- **Akses:** http://localhost:8080
- **Login:** bee / bug (kredensial lab default)
- **Security level:** Low (security_level = 0)
- **Stack:** PHP 5.5.9, Apache 2.4.7, MySQL, Ubuntu

Ruang Lingkup Audit

- **Jenis uji:** black-box dan grey-box
- **In-scope:** web app layer (injection, XSS, info disclosure, misconfig, header)
- **Out-of-scope:** audit OS/host, DoS, social engineering, sistem nyata
- **Sifat:** lab terisolasi, aplikasi sengaja rentan

Alur Audit: 5 Tahap



Tools yang Digunakan

Tool	Versi	Fungsi
Nikto	2.1.5	Web server scanner (info disclosure, misconfiguration)
SQLMap	1.10.2.6	Deteksi dan eksploitasi SQL Injection otomatis
OWASP ZAP	2.17.0	Dynamic Application Security Testing (DAST)
Retire.js	5.4.3	Deteksi pustaka JavaScript usang (SCA)
Nmap + vulners	7.94SVN	Deteksi versi layanan dan pemetaan CVE server
Manual (curl, browser)	-	Verifikasi manual XSS dan kebocoran data

Kombinasi scan otomatis + eksploitasi terarah + analisis komponen + uji manual untuk menutup blind spot tiap tool.

Ringkasan Eksekutif

Audit menemukan **5 area temuan utama** dengan severity Medium hingga Critical.

Dua temuan **Critical** memungkinkan penyerang mengambil alih data sensitif tanpa autentikasi: kebocoran kredensial melalui file konfigurasi yang terekspos, dan SQL Injection yang membongkar seluruh tabel pengguna termasuk akun admin.

Aplikasi juga rentan XSS, memakai komponen End-of-Life, dan memiliki sejumlah security misconfiguration.

Distribusi Severity

Critical

2

High

2

Medium

1

Total 5 temuan utama
(plus 6 temuan Low pendukung)

Ringkasan Temuan

ID	Temuan	Severity	OWASP 2021	Tool
F-01	Sensitive Data Exposure (kredensial bocor)	Critical	A01, A02, A05	Nikto + manual
F-02	SQL Injection	Critical	A03, A02	SQLMap
F-03	Cross-Site Scripting (Reflected + Stored)	High	A03	Manual
F-04	Security Misconfiguration & Missing Headers	Medium	A05, A01	OWASP ZAP
F-05	Vulnerable & Outdated Components	High	A06	Retire.js + Nmap

F-01 Sensitive Data Exposure

OWASP 2021: A01 Broken Access Control, A02 Cryptographic Failures, A05 Security Misconfiguration

File konfigurasi dan backup berisi kredensial dapat diakses publik tanpa autentikasi. Directory indexing yang aktif menampilkan isi folder sensitif seperti /passwords/.

Dampak: kredensial DB diperoleh tanpa eksploitasi, berpotensi full database compromise.

Rekomendasi Remediasi

- Matikan directory indexing (Options -Indexes).
- Hapus file backup (.bak, .inc, .old) dari web root.
- Pindahkan file konfigurasi ke luar document root.
- Jangan simpan password plaintext, gunakan hashing kuat.
- Hapus installer (install.php) setelah instalasi.

Bukti: config.inc terekspos

```
$ curl http://localhost:8080/config.inc
$server = "localhost";
$username = "bwapp";
$password = "bwApped";
$database = "bWAPP";
```

```
/passwords/ -> heroes.xml,
web.config.bak, wp-config.bak
(password plaintext)
```

F-02 SQL Injection

OWASP 2021: A03 Injection, A02 Cryptographic Failures

Parameter title pada modul SQL Injection (GET/Search) tidak disanitasi, sehingga input pengguna dieksekusi langsung sebagai bagian dari query SQL.

Dampak: akses baca penuh ke database; hash SHA1 unsalted mudah dipecahkan.

Rekomendasi Remediasi

- Gunakan prepared statements / parameterized query (PDO, MySQLi).
- Terapkan input validation berbasis whitelist.
- Ganti hashing password ke bcrypt atau argon2 dengan salt unik.
- Terapkan least privilege pada akun database aplikasi.

Bukti: SQLMap dump bWAPP.users

Parameter 'title' rentan 4 teknik:
boolean-blind, error, time-blind, UNION

```
Database: bWAPP Table: users
id | login | admin | password(SHA1)
1 | A.I.M. | 1 | 6885858486..affd0
2 | bee | 1 | 6885858486..affd0
echo -n "bug" | shasum -> match
Password admin dipulihkan: "bug"
```

F-03 Cross-Site Scripting (XSS)

OWASP 2021: A03 Injection (Cross-Site Scripting)

Aplikasi tidak melakukan output encoding maupun sanitasi input. Ditemukan dua varian: Reflected (GET) dan Stored (Blog) yang tersimpan permanen.

Dampak: pencurian session cookie, session hijacking, defacement, phishing. Diperparah cookie tanpa HttpOnly.

Rekomendasi Remediasi

- Terapkan output encoding sesuai konteks (htmlspecialchars).
- Lakukan input validation di sisi server.
- Pasang Content Security Policy (CSP).
- Set flag HttpOnly dan Secure pada cookie session.

Bukti: payload tereksekusi

```
Reflected (xss_get.php, firstname):  
Welcome <script>alert('XSS-bWAPP')  
      </script> test
```

```
Stored (xss_stored_1.php):  
<td><script>alert('Stored-XSS-  
      by-Audit')</script></td>
```

(payload stored telah dibersihkan)

F-04 Security Misconfiguration

OWASP 2021: A05 Security Misconfiguration, A01 Broken Access Control

OWASP ZAP menemukan sejumlah kesalahan konfigurasi dan header keamanan yang hilang: total 5 temuan Medium dan 6 temuan Low pendukung.

Dampak: memperbesar peluang CSRF, clickjacking, dan info disclosure bagi penyerang.

Rekomendasi Remediasi

- Tambahkan token Anti-CSRF unik pada setiap form pengubah state.
- Set header CSP, X-Frame-Options, X-Content-Type-Options: nosniff.
- Set flag HttpOnly, Secure, SameSite pada cookie.
- Gunakan custom error page; sembunyikan banner versi.
- Update komponen EOL (PHP 5.5.9, Apache 2.4.7).

Bukti: temuan Medium dari ZAP

- Absence of Anti-CSRF Tokens (CWE-352)
- Application Error Disclosure (CWE-550)
- CSP Header Not Set (CWE-693)
- Directory Browsing (CWE-548)
- Missing Anti-clickjacking (CWE-1021)

Low: cookie tanpa HttpOnly/SameSite,
banner Apache/2.4.7 & PHP/5.5.9 bocor,
X-Content-Type-Options tak diset

F-05 Vulnerable & Outdated Components

OWASP 2021: A06 Vulnerable and Outdated Components

Aplikasi berjalan di atas komponen End-of-Life pada sisi klien (jQuery) dan server (Apache, PHP) yang tidak lagi menerima patch keamanan.

Dampak: permukaan serangan luas (XSS, prototype pollution, request smuggling) dengan banyak exploit publik.

Rekomendasi Remediasi

- Perbarui jQuery ke versi didukung (3.5.0+).
- Update Apache; migrasikan PHP 5.5.9 ke PHP 8.x.
- Terapkan patch management dan SCA berkala.
- Skor per-CVE potensial (berbasis banner); fakta EOL terkonfirmasi High.

Bukti: Retire.js + Nmap vulners

```
jQuery 1.4.4 (2010, EOL) -> 7 CVE:  
CVE-2020-11023, CVE-2019-11358,  
CVE-2020-7656, CVE-2015-9251, dll
```

```
Apache httpd 2.4.7 (Ubuntu):  
vulners cocokkan 106 CVE unik  
(Critical 24 | High 42 | Medium 40)
```

```
PHP 5.5.9 -> EOL sejak Juli 2016
```

Keterbatasan Automated Scanner

OWASP ZAP melaporkan 0 temuan High, padahal pengujian manual dan SQLMap membuktikan adanya SQL Injection (Critical) dan Stored XSS (High) pada aplikasi yang sama.

Penyebab: ZAP hanya meng-crawl halaman permukaan dan tidak masuk ke modul kerentanan di balik autentikasi atau yang tidak ter-link otomatis. Automated DAST scanner memiliki blind spot, sehingga audit yang baik wajib mengombinasikan scan otomatis, eksploitasi terarah, dan uji manual.

Cross-Validation (dikonfirmasi 2 tool berbeda: Nikto + ZAP)

- Directory Browsing aktif
- Kebocoran banner versi server (Apache/2.4.7)
- Missing X-Frame-Options (anti-clickjacking)
- Cookie session tanpa flag HttpOnly

Best Practice dan Keamanan Lab

✓ YANG HARUS DILAKUKAN

- Bind Docker hanya ke localhost.
- Gunakan Host-only Adapter pada VM.
- Ambil snapshot sebelum eksploitasi.
- Dokumentasikan setiap langkah (payload, screenshot, respons).
- Bersihkan payload stored setelah verifikasi.

✗ YANG TIDAK BOLEH

- Expose port ke jaringan publik.
- Menjalankan di komputer produksi.
- Menggunakan payload terhadap target nyata tanpa izin tertulis (ilegal).
- Memperlakukan data dump sebagai kredensial nyata (ini user seeded bWAPP).

Kesimpulan

Kerentanan serius dan beragam. bWAPP mencakup mayoritas kategori OWASP Top 10 2021.

Dua Critical jadi prioritas. Sensitive Data Exposure dan SQL Injection memungkinkan kompromi data langsung.

Komponen usang memperluas serangan. A06: jQuery 1.4.4, Apache 2.4.7, dan PHP 5.5.9 sudah End-of-Life.

Kombinasi metode terbukti penting. Tidak ada satu tool pun yang menemukan seluruh kerentanan.

Media latihan audit yang efektif. Dari identifikasi, eksploitasi, hingga rekomendasi selaras standar industri.

Terima Kasih

Ada pertanyaan?

Auditor: Ravi Arnan Irianto - Mata Kuliah IT Audit

Demo cepat: <http://localhost:8080> (login bee / bug)

Referensi: owasp.org/Top10 - itsecgames.com